

2 Reduce Attack Surface and Vulnerabilities

2.1 Internal Data Flow Security

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•		
<u>Control Definition</u> Control Objective: Ensure the confidentiality, integrity, and authenticity of application data flows between user's Swift-related components. In-scope components: - On-premises or remote (hosted and or operated by a third party, or both) user's Swift infrastructure and related components (including new HSM) Risk Drivers: - loss of sensitive data confidentiality - loss of sensitive data integrity - unauthenticated system traffic - unauthorised access						
<u>Implementation Guidance</u> Control Statement: Confidentiality, integrity, and authentication mechanisms are implemented to protect Swift-related component-to-component or system-to-system data flows. Control Context: The protection of internal data flows safeguards against unintended disclosure, modification, and access of the data while in transit. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - All data flows between Swift-related components are protected using a secure mechanism (for example, by using Local Authentication (LAU) in combination with a confidentiality protection²⁰ or by using two-way TLS) to support the confidentiality, integrity, and authentication of the data flows. This includes the following data flows: - Local RMA application to messaging interface - GUI to messaging interface - GUI to communication interface - messaging interface to communication interface - the flows between components or secure zones which span over multiples on-premises or remote (such as in the cloud) environments or a combination.						

²⁰ Such as one-way TLS

- Secure protocols use current, commonly accepted cryptographic algorithms (for example, AES²¹ and ECDHE²²) with key lengths in line with the current best practices. For more information about cryptographic algorithms that support secure protocols, see the [Knowledge Base article 5021566](#).
- Credentials and private or bilateral (cryptographic) keys used, and usually stored, by applications to secure flows are protected. This can be achieved through a large spectrum of methods, from definition and usage of secure coding guidelines to the use of specific solutions such as Key Management Service or System (KMS), secured based on the user's risk management.

²¹ Advanced Encryption Standard

²² Elliptic Curve Diffie-Hellman Ephemeral